

# Agent eBPF Filter 商业计划书

负责人待填

## Agent eBPF Filter 商业计划书

### 0. 执行摘要

Agent eBPF Filter 是面向 AI Agent 与开发者 CLI 的运行时安全与可观测平台。随着 Codex、Claude Code、Gemini CLI、Copilot、MCP 工具和企业内部自动化 Agent 进入研发流程，企业与高校正在面对新的安全问题：Agent 不只生成文本，还会启动 shell、安装依赖、读写文件、访问网络、操作浏览器和调用外部工具。传统提示词安全无法证明真实执行行为，传统 EDR 又缺少 Agent 任务语义。本项目以 eBPF 为事实采集和内核阻断底座，将 Agent 的语义声明、操作系统事实和策略控制统一起来，形成“黑匣子 + 刹车系统”。

商业化路径采取“开源核心 + 专业版 + 私有化 + 教育培训”的组合：开源基础观测能力积累开发者社区；专业版服务高校实验室、AI coding 团队和安全研发团队；私有化版本进入企业内网与研发效能平台；教育版配套课程、实验和竞赛训练营。

注：本计划书中的价格、收入和客户数量为校赛版测算，提交前应使用真实访谈、试点意向、合同报价或学校/企业反馈进行替换。

### 1. 项目愿景

让 AI Agent 在真实开发环境中“敢用、可控、可证据化”。

- **敢用**：不是简单禁用 Agent，而是在可观测、可回放、可审计的边界内使用。
- **可控**：对高风险文件、网络、命令执行路径提供确定性阻断和运行时门控。
- **可证据化**：将每次 Agent 执行链转化为时间戳、PID/TID、文件、网络、策略、告警和图谱证据。

## 2. 市场痛点

### 2.1 AI Agent 正在进入高权限 workflow

AI 编码助手已经能够读取仓库、修改文件、执行测试、安装依赖、访问外部网络并提交 PR。运维、数据分析、客服和安全运营场景中的 Agent 也开始拥有工具调用、浏览器操作、数据库查询和脚本执行能力。外部调研显示，Agent 的主要风险不是“回答错”本身，而是工具权限、文件系统、网络访问、MCP/skills 配置和开发者本机凭据被串联成高权限执行链。GitGuardian 2026 报告将 AI 辅助提交、AI service key 和 MCP 配置列为 secrets sprawl 的增长因素；OWASP LLM06 则把过度功能、过度权限、过度自治列为 Agent 主要风险。

这意味着企业用户的真实问题不是“是否允许使用 Agent”，而是“如何在不牺牲研发效率的情况下，持续看见并约束 Agent 到底做了什么”。

### 2.2 现有方案缺口

| 方案          | 能力              | 缺口                                           |
|-------------|-----------------|----------------------------------------------|
| Prompt/内容安全 | 检查输入输出、阻止敏感文本   | 看不到真实进程、文件、网络行为。                             |
| EDR/主机安全    | 监控系统行为、恶意软件检测   | 不理解 Agent run/task/tool_call 语义，难判断是否偏离用户意图。 |
| DevOps 日志   | 记录 CI、命令输出、应用日志 | 子进程、系统调用、网络连接证据不完整。                          |
| 沙箱/容器       | 隔离执行环境          | 粒度粗，难以解释每一步行为，也不适合所有本地开发场景。                  |
| API 网关      | 管控模型 API 调用     | 无法覆盖本地 shell、文件系统、依赖脚本和浏览器行                  |

| 方案 | 能力 | 缺口 |
|----|----|----|
|    |    | 为。 |

2.3 高价值痛点

- **密钥外泄**：Agent 读取 .ssh、.env、云凭证、浏览器 cookie、MCP 配置或 CI token 后，普通日志很难证明是否外传。
- **只读任务漂移**：Agent 在“只读分析/PR review”任务中启动 curl|bash、nc、ssh、python -c 等异常命令，用户直到事后才发现。
- **供应链执行链**：npm install、pip install、Git hooks、MCP skills 或依赖脚本借 Agent 权限访问本机资源。
- **多 Agent 协作冲突**：多个 Agent 同时修改同一文件或同一任务链，缺少 PID、task、tool\_call 级别归因。
- **审计不可证明**：企业想使用 Agent 提效，但安全/合规团队缺少可验证、可回放、可提交给管理层的证据材料。

2.4 用户痛点画像

| 用户角色          | 真实痛点                                          | 产品话术                                         |
|---------------|-----------------------------------------------|----------------------------------------------|
| AI coding 开发者 | 想提效，但担心 Agent 读错文件、跑危险命令、外联未知地址。              | 不禁止使用 Agent，而是给每次执行装“黑匣子 + 刹车”。              |
| 企业安全团队        | EDR 有系统行为，Prompt 网关有文本，但二者无法对齐到同一个 tool call。 | 将 Agent run/task/tool 与 PID、文件、网络、策略决策串成证据链。 |
| 研发效能平台        | 推广 Agent 需要可审计、可灰度、可回滚的管控手段。                  | 先观察、再告警、再阻断，逐步沉淀团队策略模板。                      |
| 高校/实验室        | 希望项目既有硬核系统实现，又能教学演示。                          | BPF LSM/cgroup 是硬核内核路径，低代码策略只是降              |

| 用户角色 | 真实痛点 | 产品话术   |
|------|------|--------|
|      |      | 低使用门槛。 |

### 3. 产品与解决方案

#### 3.1 产品定位

Agent eBPF Filter 是部署在 Linux 开发机、实验室服务器、企业研发节点或 Kubernetes 节点上的 Agent Runtime Security & Observability Plane。

一句话定位：把 Agent 的“承诺”与操作系统里的“事实”对齐起来。

#### 3.2 产品模块

| 模块          | 功能                                                             | 客户价值                         |
|-------------|----------------------------------------------------------------|------------------------------|
| 内核事实采集      | eBPF 捕获<br>exec/open/connect/send/<br>recv/fork/unlink 等行为     | 获得无法被普通应用日志替代的真实证据。          |
| Agent 语义接入  | wrapper、CLI hooks、<br>Python/Node 适配器                          | 知道事件来自哪个 Agent、<br>任务和工具调用。  |
| 策略阻断        | BPF LSM、cgroup、<br>wrapper<br>ALLOW/BLOCK/ALERT/R<br>EWRITE    | 将审计提升为可执行控制。                 |
| 执行图谱        | Agent Run -> Tool Call -><br>Process -><br>File/Network/Policy | 事故复盘、答辩演示、审计<br>汇报更直观。       |
| ML/LLM 风险评分 | 训练样本、benchmark、<br>原因码、建议策略                                    | 持续优化误报/漏报，不让<br>LLM 直接做内核阻断。 |
| 可视化低代码策略    | 拖拽式 eBPF/策略 workflow                                           | 降低教学、演示和非内核开<br>发者使用门槛。      |

### 3.3 典型使用流程

1. 管理员启动 Agent eBPF Filter 后端并加载 eBPF 程序。
2. 开发者通过 agent-wrapper 或 CLI hook 启动 Codex/Claude/Gemini 等工具。
3. Agent 执行任务时，系统记录工具意图、进程树、文件访问、网络流和策略决策。
4. 如果出现敏感文件访问、异常网络外联、下载即执行、工作区逃逸等行为，系统告警或阻断。
5. 用户在 Execution Graph 中回放证据链，并一键生成 allow/block 规则或训练样本。

## 4. 核心技术壁垒

### 4.1 eBPF 与 BPF LSM 工程壁垒

系统覆盖 syscall tracepoints、cgroup/connect、UDP sendmsg、BPF LSM、TLS uprobes（默认关闭）等多类 hook，并处理 pin maps/links、权限、自提升、内核兼容和缺失 tracepoint 容错。这类能力需要系统编程、内核安全和 Go 工程协同，不容易被只做前端或单纯大模型应用的团队快速复制。

### 4.2 Agent 语义与 OS 事实的统一事件模型

项目把 hook/wrapper 语义、eBPF 事实、策略决策、ML/LLM 风险评分统一到 EventEnvelope，并保留 agent\_run\_id、task\_id、tool\_call\_id、trace\_id、PID/TGID/PPID、cgroup\_id 等字段。这使平台能解释“某个工具调用为什么触发某个系统行为”，而非只有零散日志。

### 4.3 执行图谱与数据闭环

图谱、录制、回放、导出、训练样本、基准测试连接成闭环。越多团队使用，越能积累高质量 Agent 行为样本与规则模板，形成产品数据资产。

4.4 安全边界设计

项目明确区分确定性阻断与智能分析：内核/cgroup/wrapper 策略负责同步阻断，ML/LLM 只提供解释、排序和建议，避免把不可解释模型直接放到高风险内核决策链路中。

4.5 代码实现形成的可防御壁垒

本项目的壁垒不只是“知道 Agent 安全有风险”，而是已经把风险落到 Linux 运行时证据与控制路径：

- lsm\_enforcer.c 在 BPF LSM 决策点返回 -EACCES，证明可以在行为完成前阻断。
- cgroup\_sandbox.c 覆盖 TCP/UDP connect 与 UDP sendmsg，补上未连接 UDP sendto/sendmsg 的外联缺口。
- event\_context.go 将 Agent 上下文继承到子进程，解决 shell/python/node/git/npm/curl 行为归因。
- semantic\_alerts.go 将密钥访问、异常外联、工作区逃逸、资源浪费循环、多 Agent 文件竞争转化为可解释告警。
- ExecutionGraph 将事件串成可演示、可复盘、可导出的图谱，直接服务安全审计和竞赛答辩。

5. 目标市场与客户画像

| 客户           | 需求                         | 切入点                                 |
|--------------|----------------------------|-------------------------------------|
| 高校实验室        | AI Agent 安全研究、eBPF 教学、竞赛项目 | 教育版、实验脚本、可视化演示、论文/软著成果。             |
| AI coding 团队 | 使用 Agent 提升研发效率但担心越权       | 单机/团队版，监控敏感路径、网络外联和依赖脚本。            |
| 企业安全团队       | 合规审计、主机证据、事件复盘             | 私有化部署、审计报表、SIEM/Prometheus/OTLP 集成。 |

| 客户       | 需求                                       | 切入点                       |
|----------|------------------------------------------|---------------------------|
| 研发效能平台   | 管理<br>Codex/Claude/Gemini/Co<br>pilot 使用 | wrapper、hooks、统一策略、团队仪表盘。 |
| CTF/培训机构 | 构造 Agent 攻防演练环境                          | 训练营、靶场模板、replay 数据集。      |

## 6. 竞品与差异化

| 类别              | 代表能力              | 本项目差异化                                           |
|-----------------|-------------------|--------------------------------------------------|
| 传统 EDR          | 进程/文件/网络威胁检测      | 增加 Agent run/task/tool 语义，面向开发者 workflow，解释任务偏离。 |
| DevSecOps/CI 安全 | 扫描代码、依赖、镜像        | 覆盖本地运行时行为，不限 CI 环境。                              |
| LLM 安全网关        | Prompt、模型 API、敏感词 | 关注模型外的 shell、文件、网络和子进程。                          |
| 容器沙箱            | 资源隔离与粗粒度限制        | 提供细粒度证据链、图谱复盘和策略推荐。                              |
| APM/可观测性        | 指标、日志、trace       | 加入 eBPF 系统调用事实与安全阻断能力。                           |

## 7. 商业模式

### 7.1 产品版本

| 版本        | 目标客户       | 定价测算  | 功能                   |
|-----------|------------|-------|----------------------|
| Community | 个人开发者、高校课程 | 免费/开源 | 单机观测、基础告警、基础策略、手动导出。 |

| 版本            | 目标客户    | 定价测算                | 功能                                  |
|---------------|---------|---------------------|-------------------------------------|
| Team Pro      | 实验室、小团队 | 39,800 元/年起         | 多用户、策略模板、报表、团队看板、训练样本管理。            |
| Enterprise    | 企业/研究院  | 198,000 元/年起        | 私有化、多节点、SSO、审计留存、SIEM/OTLP 集成、定制策略。 |
| Education Kit | 高校/培训   | 30,000 元/套起         | 课程实验、讲义、靶场脚本、答辩/竞赛辅导。               |
| Consulting    | 企业专项    | 50,000-200,000 元/项目 | Agent 安全基线、PoC、红队 replay、策略调优。      |

## 7.2 收入测算（校赛版）

| 年度    | 客户假设                               | 收入     | 主要成本   | 净现金流   |
|-------|------------------------------------|--------|--------|--------|
| 第 1 年 | 5 个高校/实验室试点，3 个企业 PoC，2 套教育包       | 80 万元  | 55 万元  | 25 万元  |
| 第 2 年 | 20 个 Team Pro，8 个 Enterprise，8 个教育 | 420 万元 | 250 万元 | 170 万元 |



| 年度    | 客户假设                                         | 收入       | 主要成本   | 净现金流   |
|-------|----------------------------------------------|----------|--------|--------|
|       | /咨询项目                                        |          |        |        |
| 第 3 年 | 60 个 Team Pro, 25 个 Enterprise, 20 个教育 /咨询项目 | 1,600 万元 | 920 万元 | 680 万元 |

成本包括研发人力、云/测试设备、市场销售、客户支持、知识产权申请和合规审计。提交前应使用真实客户访谈和报价替换上述估算。

## 8. 市场进入策略

### 8.1 第一阶段：高校与开源社区验证

- 发布开源核心版本和一键演示脚本。
- 选择 2-3 个课程/实验室做 Agent 安全实验。
- 形成演示视频、benchmark 报告、案例文章和软著材料。

### 8.2 第二阶段：AI coding 团队 PoC

- 面向正在使用 Codex、Claude Code、Gemini CLI、Copilot 的团队提供本地 PoC。
- 交付“敏感文件访问”“异常外联”“依赖脚本风险”“多 Agent 文件竞争”四类报告模板。
- 打磨 Team Pro 的策略模板、团队面板和报表。

### 8.3 第三阶段：企业私有化

- 与研发效能、终端安全、DevSecOps、SIEM 平台集成。
- 支持离线部署、审计留存、RBAC、SSO、企业策略基线。
- 通过咨询项目带动软件订阅。

9. 运营计划

| 方向    | 关键动作                               |
|-------|------------------------------------|
| 产品迭代  | 每月发布稳定版本；按客户反馈优化策略、图谱和报表。          |
| 社区建设  | 发布 eBPF + Agent 安全技术博客、演示数据集、课程实验。 |
| 销售线索  | 从高校实验室、AI coding 社群、企业安全团队建立试点名单。  |
| 交付支持  | 提供标准 PoC 文档、部署脚本、验收报告模板、远程支持。      |
| 合规与信任 | 明确不默认采集敏感明文；TLS 捕获 opt-in；数据本地化存储。 |

10. 财务与融资计划

10.1 资金用途

| 用途      | 比例  | 说明                                |
|---------|-----|-----------------------------------|
| 核心研发    | 45% | eBPF 兼容性、多节点、策略引擎、图谱与性能优化。        |
| 测试与设备   | 15% | 多内核版本、GPU/CPU、企业环境、Kubernetes 节点。 |
| 市场与试点   | 20% | 高校/企业 PoC、路演、技术内容、开源社区运营。         |
| 知识产权与合规 | 10% | 软著、专利、合同、隐                        |

| 用途   | 比例  | 说明                |
|------|-----|-------------------|
|      |     | 私与安全评估。           |
| 客户支持 | 10% | 部署文档、培训、售后和定制化交付。 |

10.2 融资规划

- 种子期：争取学校创新创业基金、导师科研经费、竞赛奖金与天使资源，用于产品验证。
- 天使轮：在完成 3-5 个企业/高校付费试点后，引入产业方或安全领域投资。
- 战略合作：与研发效能平台、云厂商、终端安全厂商或高校课程平台合作。

11. 团队与组织

| 职能      | 核心能力                       | 当前缺口              |
|---------|----------------------------|-------------------|
| 内核/eBPF | C/eBPF、BPF LSM、cgroup、内核兼容 | 需要持续增加多内核测试经验。    |
| 后端平台    | Go、API、事件模型、权限、部署          | 需要企业级 RBAC/多租户能力。 |
| 前端产品    | Vue、图可视化、低代码交互             | 需要更多用户体验打磨和设计资源。  |
| 算法评测    | 语义告警、ML、benchmark、数据集      | 需要真实场景样本与标注流程。    |
| 商业拓展    | 客户访谈、售前、试点交付               | 需要明确首批试点名单与合作证明。  |

12. 风险分析

| 风险             | 影响              | 应对                |
|----------------|-----------------|-------------------|
| Linux/eBPF 兼容性 | 不同内核版本 hook 支持差 | 缺失 tracepoint 容错、 |

| 风险       | 影响          | 应对                                     |
|----------|-------------|----------------------------------------|
|          | 异           | preflight 检查、版本矩阵测试。                   |
| 权限与安全顾虑  | 客户担心平台自身高权限 | 最小化权限、运行时 token、危险功能默认关闭、审计日志、分组件权限规划。 |
| 误报影响开发体验 | 用户可能关闭策略    | 分级告警、观察模式、推荐策略先人工确认、回放调优。              |
| 商业转化周期长  | 企业安全采购慢     | 先从教育版/PoC/咨询切入，缩短决策链。                  |
| 竞品进入     | 大厂可能集成类似能力  | 通过开源生态、垂直 Agent 语义、快速迭代和教育市场建立先发优势。    |

### 13. 社会价值与教育价值

- 提升 AI Agent 使用的安全可信程度，降低企业和个人因自动化工具误用造成的损失。
- 帮助高校学生把操作系统、网络安全、人工智能、软件工程和创新创业知识融合到真实项目。
- 推动 eBPF 技术在国产 AI 工具治理、安全审计和开发者基础设施中的应用。
- 形成可复用的教学实验、竞赛案例和开源社区资源。

### 14. 里程碑

| 时间      | 里程碑         | 验收证据                           |
|---------|-------------|--------------------------------|
| 2026.06 | 校赛材料与演示链路完成 | DOCX/PDF/PPTX、5 分钟视频、可运行 demo。 |

| 时间      | 里程碑       | 验收证据                        |
|---------|-----------|-----------------------------|
| 2026.08 | 试点版发布     | 2 个高校/实验室试点反馈、benchmark 报告。 |
| 2026.10 | 专业版 MVP   | 多用户、报表、策略模板、导出能力。           |
| 2027.03 | 知识产权与首批付费 | 软著/专利申请、首批合同/意向书。           |
| 2027.12 | 企业版拓展     | 私有化部署案例、年度收入目标复盘。           |

## 15. 调研来源与客户验证计划

### 15.1 已纳入的外部调研来源

- OWASP LLM06:2025 Excessive Agency：用于说明过度权限、过度功能、过度自治的风险。
- OWASP Agentic AI Threats and Mitigations / Agentic Skills Top 10：用于说明 agent skills、工具链与多步执行风险。
- Five Eyes / CISA / NSA / NCSC Agentic AI 采用指南：用于说明企业采用 Agent 时需要可见性、最小权限、隔离和持续评估。
- GitGuardian State of Secrets Sprawl 2026：用于说明 AI 辅助开发、MCP 配置和 AI service key 泄露加剧开发者本机风险。
- NIST AI 600-1 / AI RMF：用于说明 AI 治理框架需要落地到运行时证据、测量和管理。

### 15.2 后续客户验证计划

1. 访谈 5-10 名已使用 Codex/Claude Code/Gemini CLI/Copilot 的学生或开发者，验证“只读任务漂移、密钥访问、异常外联”是否为高频担忧。
2. 在实验室或课程环境中跑 3 个演示：敏感文件访问、异常网络外联、BPF LSM 阻断，记录观众反馈。

3. 用 os-enforcement smoke 与 execution graph 形成可交付报告模板，作为企业 PoC 的验收材料。
4. 用真实反馈修订 Team Pro 与 Education Kit 定价和功能优先级。

## 16. 附录：提交前需补证据

1. 真实用户访谈纪要：至少 10 份高校/企业/开发者访谈。
2. 竞品调研表：不少于 5 类产品，列出价格、功能、差异化。
3. Demo 截图与视频：Dashboard、Execution Graph、Security Policies、阻断效果。
4. 技术测试报告：性能开销、阻断成功率、事件延迟、误报/漏报。
5. 知识产权材料：代码仓库、软著、专利、论文或开源贡献说明。
6. 试点证明：导师实验室、课程或企业 PoC 意向书。